PRADITA University

IT40813 · IT Governance, Risk & Compliance

COBIT 2019

Sistem dan Faktor Desain

Pertemuan 04

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. COBIT sebagai Kerangka
3. Prinsip dan Komponen
4. Model Inti
5. Faktor Desain
6. Goals Cascade
7. Kapabilitas
8. Kaitan dan Versi
9. Aktivitas dan Penutup

Direksi berkata:
Terapkan COBIT.
Mulai dari mana?

Tujuan Pembelajaran

- Menjelaskan komponen sistem tata kelola dan 40 objektif tata kelola dan manajemen dalam COBIT 2019.
- Menerapkan faktor desain dan *goals cascade* untuk memilih objektif yang paling penting bagi sebuah organisasi.
- Menilai tingkat kapabilitas saat ini untuk objektif prioritas berdasarkan bukti, bukan pengakuan.

Masalah: Perintah Tanpa Masalah yang Jelas

PRADITA University

- Misalkan audit menemukan 6 dari 30 akun vendor masih aktif setelah penugasan berakhir.
- Direktur utama berkata “Terapkan COBIT”. Kepala TI membuka daftar 40 objektif.
- Konsultan menawarkan penilaian semua objektif dengan satu angka rata-rata.
- Direktur pelayanan bertanya apakah angka itu memperpendek antrean. Tidak ada jawaban.
- Kerangka diperlakukan sebagai daftar pekerjaan seragam. Prosedur bertambah, akun vendor tetap tidak ditinjau.

Diagram Konsep Bab 4

IT40813 / BAB 04 / DIAGRAM KONSEP

COBIT 2019: tujuan, faktor desain, dan bukti kapabilitas



Versi model dicatat pada artefak. Prioritas lokal dan hasil pemetaan tidak otomatis menjadi keluaran resmi COBIT Toolkit.

Empat Publikasi Inti COBIT 2019

PRADITA University

Publikasi	Pertanyaan yang dijawab
Framework: Introduction and Methodology	Apa konsep dan prinsip kerangka ini?
Framework: Governance and Management Objectives	Apa isi tiap objektif, praktik, dan aktivitasnya?
Design Guide	Bagaimana merancang sistem sesuai konteks organisasi?
Implementation Guide	Bagaimana menerapkan dan mengoptimalkan rancangan itu?

Isi COBIT bersifat umum dan perlu disesuaikan. Publikasi desain dan implementasi sudah menyatakan arah itu pada judulnya.

Katalog Bukan Rencana Perbaikan

PRADITA University

- Analogi: bengkel punya katalog ratusan suku cadang, tetapi montir memilih bagian setelah memeriksa mobil.
- Kadam (2020): 4 objektif memuat 25 praktik dan 140 aktivitas, rata-rata 35 per objektif.
- Perkiraan kasar: 40 objektif sekitar 1.400 aktivitas. Dengan 30 menit per aktivitas: 700 jam, atau 87,5 hari kerja.
- Bab 1: 52 staf TI dibagi 40 objektif = 1,3 orang. Dibagi 6 objektif = sekitar 8,7 orang.
- Sertifikat 4 dari 52 staf (7,7 persen) tidak menjawab apakah 120 akun sudah ditinjau.

Kasus Medikara: Dari Perintah ke Tiga Pertanyaan

PRADITA University

- Masalah layanan mana yang paling merugikan? Siapa pemiliknya? Bukti apa yang diterima komite?
- Misalkan konsultan menawarkan Rp600 juta untuk 40 objektif.
- Rp600 juta melewati batas komite Rp400 juta, sehingga keputusan naik ke direksi.
- Bila biaya sebanding jumlah objektif, 6 objektif setara 15 persen, sekitar Rp90 juta.
- Rp90 juta di bawah batas Rp100 juta untuk kepala TI, dengan masukan pemilik layanan.

Enam Prinsip Sistem Tata Kelola

Prinsip	Contoh pada Medikara (pengandaian)
Nilai bagi pemangku kepentingan	Ukuran utama: kerahasiaan data dan waktu tunggu, bukan jumlah prosedur
Pendekatan menyeluruh	AC-01 memerlukan proses, daftar akun, pemilik, dan alat
Sistem yang dinamis	Akuisisi fasilitas baru memicu penilaian ulang
Tata kelola berbeda dari manajemen	Komite 9 anggota menilai arah; kepala TI menjalankan rencana
Disesuaikan dengan kebutuhan	Medikara+ buatan vendor menaikkan perhatian pada vendor
Mencakup seluruh fungsi	Cakupan 36 fasilitas, bukan hanya divisi TI pusat

Tiga prinsip kerangka: model konseptual; terbuka dan luwes; selaras dengan standar, kerangka, dan regulasi utama.

Tujuh Komponen pada AC-01

PRADITA University

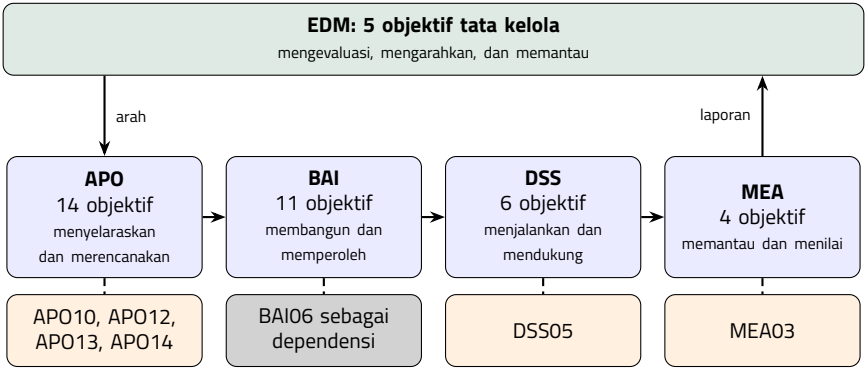
Komponen	Penerapan AC-01	Bukti
Proses	Tarik daftar, tandai, cabut, catat	Catatan peninjauan bulanan
Struktur organisasi	Pengelola vendor, pemilik layanan, eskalasi	Mandat dan daftar peran
Prinsip, kebijakan, dan prosedur	Akun per orang, batas waktu pencabutan	Kebijakan akses yang disahkan
Informasi	Populasi akun dan tanggal berakhir penugasan	Daftar 120 akun dan penugasan
Budaya, etika, dan perilaku	Peninjau berani mencabut akses vendor penting	Tindak lanjut atas keberatan
Orang, keterampilan, dan kompetensi	Peninjau memahami peran akses	Pelatihan dan hasil uji sampel
Layanan, infrastruktur, dan aplikasi	Alat pencatatan serta pencabutan	Rekam perubahan akses

Analogi dan Contoh Berangka

- Perpustakaan butuh aturan, petugas, katalog, perangkat, dan kebiasaan mengembalikan. Prosedur saja tidak membuat buku kembali ke rak.
- Misalkan daftar yang diterima peninjau hanya memuat 108 dari 120 akun. Sebanyak 12 akun (10 persen) luput.
- Komponen yang lemah adalah informasi, jadi menambah prosedur tidak menutup celah.
- Misalkan 1 rumah sakit berbeda dari 4 lainnya karena SIMRS hasil akuisisi. Penyesuaian dijelaskan, bukan dinilai dari kesamaan format.
- Komite tidak mencabut 24 akun. Komite memastikan ada pemilik dan melihat hasilnya.

Model Inti:
40 Objektif
dalam Lima Domain

Lima Domain dan Enam Objektif Awal



5 + 14 + 11 + 6 + 4 = 40 objektif. Baris bawah: enam objektif awal pengandaian Medikara.

Contoh Nama Objektif yang Sudah Dicocokkan

PRADITA University

Domain	Fokus	Contoh objektif
EDM, 5	Arah serta pengawasan	EDM03 *Ensured risk optimization*
APO, 14	Perencanaan, pengorganisasian	APO10 *Managed vendors*; APO12 *Managed risk*; APO13 *Managed security*; APO14 *Managed data*
BAI, 11	Perolehan, perubahan solusi	BAI06 *Managed IT changes*; BAI11 *Managed projects*
DSS, 6	Operasi serta layanan	DSS04 *Managed continuity*; DSS05 *Managed security services*
MEA, 4	Pemantauan serta penilaian	MEA03 *Managed compliance with external requirements*; MEA04 *Managed assurance*

Katalog di `sources/chapter04`: 31 nama sudah dicocokkan, 9 ditandai “perlu dicocokkan”.

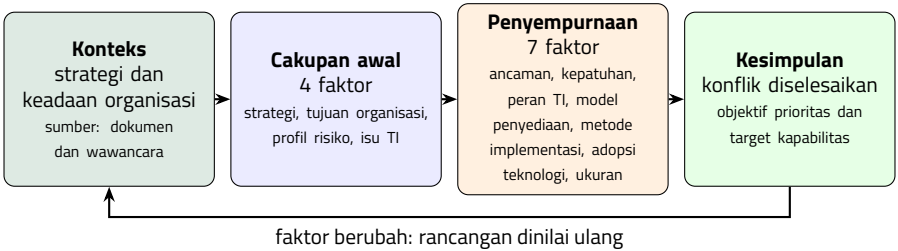
Objektif, Praktik, Aktivitas

- Objektif menyatakan hasil. Isinya diuraikan menjadi praktik dan aktivitas. DSS04 memiliki 8 praktik.
- Tiap aktivitas dikaitkan dengan satu tingkat kapabilitas (Thomas, 2018).
- Analogi: peta layanan rumah sakit membagi unit, tetapi perjalanan satu pasien melewati beberapa unit.
- Misalkan temuan 6 dari 30 akun mengarah pada APO10 dan DSS05, yang dinilai bersama.
- Misalkan pembaruan aplikasi membuat 2.400 dari 96.000 data (2,5 persen) tidak cocok: BAI06 dan APO14.

PRADITA University

Sebelas Faktor Desain dan Focus Area

Faktor Dipakai Bertahap



Empat faktor membuka cakupan awal, tujuh faktor memperhalus, lalu konflik diselesaikan. Analogi: jaringan air rumah satu lantai berbeda dari jaringan air rumah sakit.

Sebelas Faktor pada Medikara

PRADITA University

Faktor	Nilai pada Medikara	Status
Strategi organisasi	*Client service/stability* tertinggi	Pengandaian
Tujuan organisasi	EG06, EG03, EG12	Pengandaian
Profil risiko	*Third-party/supplier incidents*; R-01	Insiden: fakta
Isu terkait TI	Temuan audit, layanan vendor, integrasi data	Fakta kasus
Ancaman	*High* 75 persen, *normal* 25 persen	Pengandaian
Kebutuhan kepatuhan	*High*: K-01 sampai K-16 pada 36 fasilitas	Register C1
Peran TI	*Factory* dan *turnaround*	Pengandaian
Model penyediaan	Medikara+ vendor; SIMRS *on-premise*	Fakta kasus
Metode implementasi	*Traditional* 70, *agile* 25, DevOps 5 persen	Pengandaian
Strategi adopsi teknologi	*Follower*: *cloud* bertahap sampai 2030	Pengandaian
Ukuran organisasi	Sekitar 4.800 karyawan, 52 staf TI	Fakta kasus

Konteks Mengubah Pilihan: Dua Rumah Sakit

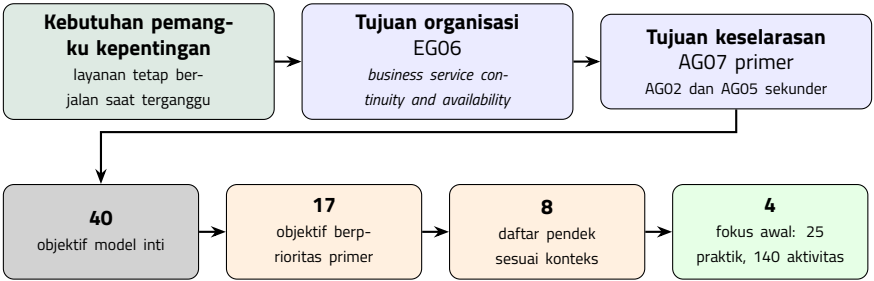
PRADITA University

- Denpasar: 170 karyawan, 75 persen *outsourcing*, lima objektif: APO12, APO13, BAI06, DSS04, DSS05.
- Kediri: DSS05, APO07, dan APO12. Hanya 2 objektif sama dari 6 yang berbeda.
- Studi pertama menyebut 11 faktor, studi kedua 10. Perbedaan metode perlu dicatat.
- Medikara: sekitar 4.800 karyawan, 19,2 kali batas 250 pada studi Denpasar. Klinik mitra 60 karyawan masuk rentang.
- Misalkan 36 fasilitas menjadi 38 (naik 5,6 persen). Tujuan sama, isu akses dinilai ulang.

Focus Area Bukan Domain Keenam

- Faktor desain menggambarkan keadaan organisasi. *Focus area* memberi perhatian pada satu tema.
- Panduan ISACA: DevOps, risiko informasi dan teknologi, keamanan informasi, organisasi kecil dan menengah.
- Analogi: klinik jantung tetap memakai laboratorium, farmasi, dan rekam medis yang sama.
- Misalkan tim platform 6 orang memakai panduan DevOps. Peninjauan 120 akun vendor tetap perlu dijawab.
- Misalkan klinik mitra punya 2 staf TI. Panduan organisasi kecil lebih masuk akal sebagai titik awal.

Rantai Tujuan: Contoh Kadam (2020)



COBIT 2019 memuat 13 EG dan 13 AG. Analogi: rencana perjalanan mulai dari tujuan, bukan kenyamanan kursi.

Rantai Prioritas Medikara

Kebutuhan	EG	AG	Objektif	Status pemetaan
Kerahasiaan data pasien	EG06	AG07	APO13; DSS05	Tercantum pada sumber
Vendor dapat dipertanggungjawabkan	EG06	AG05	APO10	Tercantum pada sumber
Risiko layanan terkendali	EG02	AG02	APO12	Penafsiran bab
Identitas pasien konsisten	EG12	AG08	APO14	Penafsiran bab
Kewajiban dapat dibuktikan	EG03	Belum ditetapkan	MEA03	Penafsiran bab

Rafeq dan Elangovan (2021) memakai EG06 yang sama, tetapi memilih DSS04 dari enam objektif primer AG07. Alasan harus tertulis.

Skor Lokal: Alat Diskusi, Bukan Keluaran Resmi

PRADITA University

Objektif	Risiko	Kewajiban	Strategi	Total	Keputusan
APO10	5	4	3	12	Masuk
DSS05	5	5	2	12	Masuk
APO13	4	4	3	11	Masuk
APO14	3	3	5	11	Masuk
APO12	4	3	3	10	Masuk
MEA03	2	5	3	10	Masuk
DSS04	3	4	3	10	Ditunda ke Bab 10
BAI06	3	2	4	9	Dependensi
APO09	3	2	2	7	Ditunda

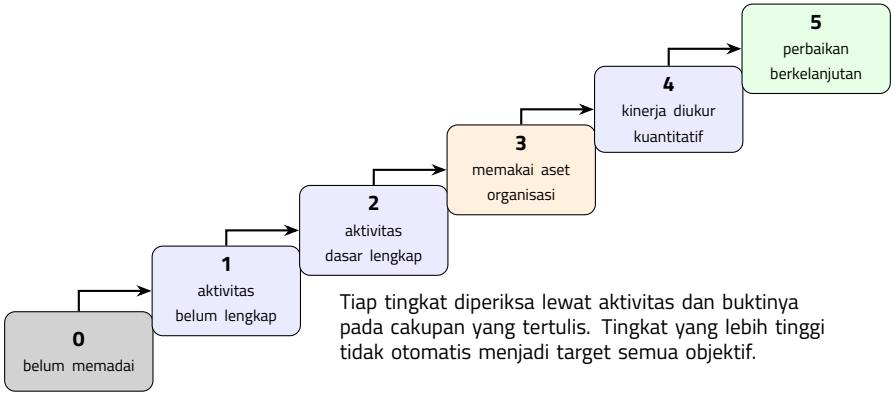
Kasus Medikara: Enam Objektif Awal

PRADITA University

- Misalkan pilihan: APO10, APO12, APO13, APO14, DSS05, dan MEA03. BAI06 sebagai dependensi.
- Tiga objektif bernilai 10, tersisa dua tempat. Alasan memutuskan: R-01 dan 16 baris register.
- DSS04 ditunda ke Bab 10, tetapi 36 prosedur dan 144 uji pemulihan per tahun tetap berjalan.
- Bila bobot kewajiban digandakan: APO12 turun ke urutan ketujuh, DSS04 masuk enam besar.
- Enam objektif setara 210 aktivitas atau 105 jam, jauh dari 700 jam untuk 40 objektif.

Kapabilitas:
Bukti, Bukan Pengakuan

Tingkat Kapabilitas 0 sampai 5



Tiap tingkat diperiksa lewat aktivitas dan buktinya pada cakupan yang tertulis. Tingkat yang lebih tinggi tidak otomatis menjadi target semua objektif.

Skala mengacu pada CMMI. Skala COBIT 5 berbasis ISO/IEC 33000 tidak boleh dipindahkan begitu saja.

Peringkat Capaian dan Aturan Penetapan

Peringkat	Souza Neto dan rekan	Studi Denpasar
N, *not achieved*	Kurang dari 15 persen	0 sampai 14 persen
P, *partially achieved*	15 sampai 50 persen	15 sampai 49 persen
L, *largely achieved*	50 sampai 85 persen	50 sampai 84 persen
F, *fully achieved*	Lebih dari 85 persen	85 sampai 100 persen

- Dua studi rumah sakit: satu tingkat tercapai bila capaian penuh. Denpasar: 85 persen atau lebih.
- Kediri: APO07 80,55 persen pada tingkat 2, peringkat L, tetap tingkat 1.
- Aturan perlu ditulis dan dicocokkan ke publikasi ISACA sebelum asesmen formal.

Membaca Dua Studi Secara Kritis

PRADITA University

Aspek	Rumah Sakit Umum Bhakti Rahayu	Rumah Sakit Wilujeng
Tingkat saat ini	APO12, DSS04: 1; APO13, BAI06, DSS05: 2	DSS05, APO07, APO12: 1
Sumber data	Kuesioner 5 karyawan, observasi, wawancara	Kuesioner, manajer unit TI, 1 responden sumber daya manusia
Pertanyaan pembaca	Bukti apa yang menopang jawaban?	Apakah satu manajer menilai pekerjaannya sendiri?

- Denpasar, APO12: 66, 66, 50, 50, 83 persen, rata-rata 63. Selisih 33 poin tersembunyi.
- Denpasar, APO13: kelima responden 71 persen. Lima pengamatan atau satu pendapat?
- Foto dapur bersih tidak membuktikan kebersihan sepanjang bulan.

Bukti dan Batas Klaim

Klaim	Bukti yang diperlukan	Batas kesimpulan
Pekerjaan dilakukan	Contoh hasil dan pelaksana	Belum membuktikan konsistensi
Cara kerja terdefinisi	Prosedur, penerapan lintas unit	Perlu sampel beberapa periode
Kinerja diukur	Definisi metrik dan data andal	Angka tanpa tindakan belum cukup
Perbaikan berkelanjutan	Analisis, tindakan, hasil ulang	Perlu keterkaitan sebab dan hasil

Misalkan 8 dari 10 perubahan punya persetujuan, tetapi 2 perubahan darurat tanpa analisis dampak. Yang gagal justru jenis paling berisiko.

Kasus Medikara: Potret Cepat DSS05 Lewat AC-01

PRADITA University

- Audit: 6 dari 30 akun masih aktif. Peninjauan penuh: 24 dari 120 dicabut. Keduanya 20 persen.
- Sampel hanya satu lokasi, sehingga tidak diproyeksikan. Pada sampel, 24 dari 30 akun (80 persen) sesuai, peringkat *largely*.
- Bukti peninjauan hanya ada di 1 dari 5 rumah sakit.
- Kesimpulan: tingkat indikatif 1 untuk satu rumah sakit. Klaim lintas 5 rumah sakit ditolak sementara.
- AC-01 hanya satu bagian DSS05, jadi hasil ini bukan tingkat DSS05 keseluruhan.

Kaitan dengan ITIL 4 dan Tata Kelola Arsitektur

Aspek	COBIT 2019	ITIL 4	Tata kelola arsitektur
Pertanyaan	Hasil apa yang dicapai dan dibuktikan?	Bagaimana layanan dijalankan sehari-hari?	Susunan mana dipilih, siapa memutuskan?
Contoh	BAI06 perubahan TI	*Change enablement*	Keputusan pola integrasi
Bukti	Tingkat kapabilitas dan celah	Tiket dan jadwal perubahan	Catatan keputusan arsitektur
Dibahas di	Bab ini	Bab 8	IT40513

- Misalkan 10 tiket perubahan: satu bukti terbaca oleh dua kerangka.
- Integrasi Rp450 juta, toleransi 10 persen, batas Rp495 juta: forum arsitektur memutuskan pola, COBIT memeriksa pemilik dan bukti.

Transisi ke COBIT 7

Tanggal	Peristiwa (pengumuman ISACA Sydney Chapter)
26 Oktober 2026	Batas pembelian sertifikat COBIT 2019
27 Oktober	Debut COBIT 7 dan sertifikat Foundation
26 April 2027	Batas ujian COBIT 2019, sisa 177 hari dari 31 Oktober 2026

- Pada 31 Oktober 2026, halaman sumber daya COBIT yang terbaca masih menampilkan COBIT 2019.
- Teks resmi COBIT 7 belum diperoleh, jadi modul memakai model COBIT 2019.
- Perubahan pengenal tidak boleh disimpulkan dari pengumuman saja.

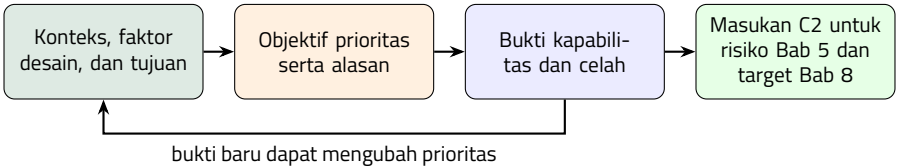
Pemeriksaan Saat Mengganti Versi

PRADITA University

Langkah	Hasil yang disimpan	Risiko bila dilewati
Tetapkan versi	Identitas model dan tanggal	Definisi bercampur
Petakan perubahan	Hubungan unsur lama dan baru	Angka tidak sebanding
Uji contoh	Penilaian ulang satu proses	Perbedaan penilai tersembunyi
Setujui transisi	Keputusan serta jadwal	Artefak tidak sinkron

Preseden: COBIT 5 punya 37 proses, COBIT 2019 punya 40. Lembar kerja lama tidak punya baris untuk APO14, BAI11, dan MEA04.

Aktivitas: Alur dan Pembagian Peran



- Pemilik konteks mengumpulkan notulen, prosedur, dan hasil kerja.
- Analis risiko mengisi risiko dan ancaman. Analis regulasi mengisi kepatuhan.
- Analis teknologi mengisi peran TI, penyediaan, dan metode implementasi.

Aktivitas: Langkah Kerja

- Isi sebelas faktor desain beserta sumber bukti dan asumsi.
- Turunkan sedikitnya tiga kebutuhan menjadi EG dan AG. Tandai sumber atau penafsiran.
- Beri skor kandidat, tulis bobot, ubah satu bobot, lalu pilih lima sampai tujuh objektif.
- Untuk tiap objektif, tentukan aktivitas, periode, populasi, dan sampel. Nilai berpasangan.
- Bandingkan dengan matriks keputusan C1 dan register kewajiban, lalu susun bukti tambahan.

Aktivitas: Luaran C2 dan Kriteria

- Luaran: lembar faktor desain, rantai tujuan, skor lokal, objektif prioritas, potret kapabilitas.
- Masuk C2 Kondisi Saat Ini. Celah diteruskan ke risiko Bab 5 dan target Bab 8.
- Kriteria: konteks 25 persen; keterlacakan 30 persen; mutu bukti 30 persen; rekomendasi 15 persen.
- Berkas: `sources/chapter04/`, lima lembar kerja dengan `README.md`.
- Data organisasi nyata wajib berizin dan dianonimkan. Data pribadi tidak boleh dipakai.

Ringkasan

PRADITA University

- Enam prinsip dan tujuh komponen: prosedur saja tidak membuat proses berjalan.
- Empat puluh objektif memberi bahasa bersama. Lingkup adalah keputusan yang dipertanggungjawabkan.
- Sebelas faktor desain dan rantai tujuan memilih prioritas. Skor lokal berguna bila bobot tertulis.
- Kapabilitas dinilai lewat aktivitas dan bukti dalam lingkup yang jelas.
- Prioritas yang dapat dijelaskan dan bukti yang dapat diperiksa lebih berguna daripada mengejar seluruh kerangka.

Latihan dan Bacaan

1. Dua rumah sakit memiliki strategi yang sama, tetapi satu mengembangkan sistem sendiri dan satu bergantung pada vendor. Bagaimana perbedaan model *sourcing* itu menggeser objektif prioritas?
2. Seorang manajer menyatakan proses manajemen perubahan sudah berada di tingkat kapabilitas 3. Bukti apa yang perlu diminta untuk menguji klaim itu?
3. Jelaskan mengapa COBIT tidak dimaksudkan untuk diterapkan seluruhnya sekaligus.

Bacaan: COBIT 2019; Kadam (2020); Souza Neto dan rekan (2019); Sari dan rekan (2025).